

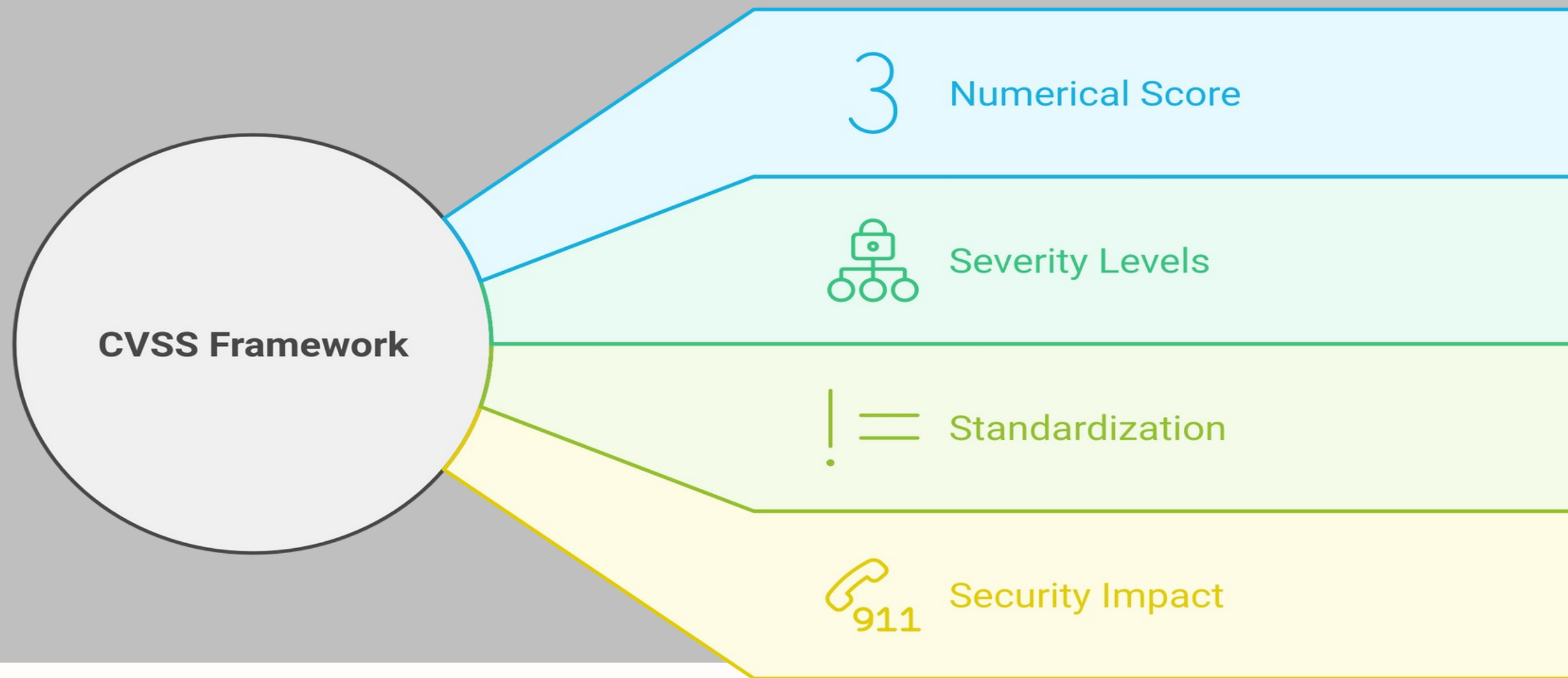
CVSS

Attempts to assess the severity of a given vulnerability

EPSS

Attempts to measure the probability of a vulnerability being used in an exploit

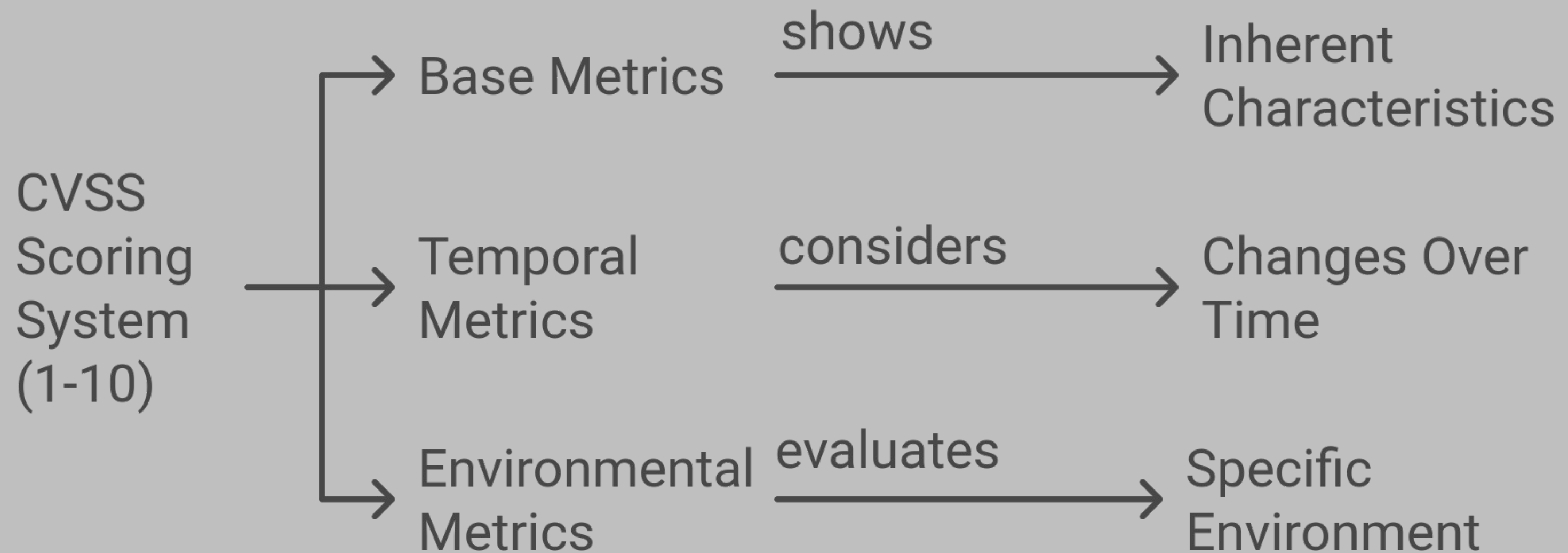
Presented by
Professor Dr. Mohammed Shafiul Alam Khan
IIT, DU



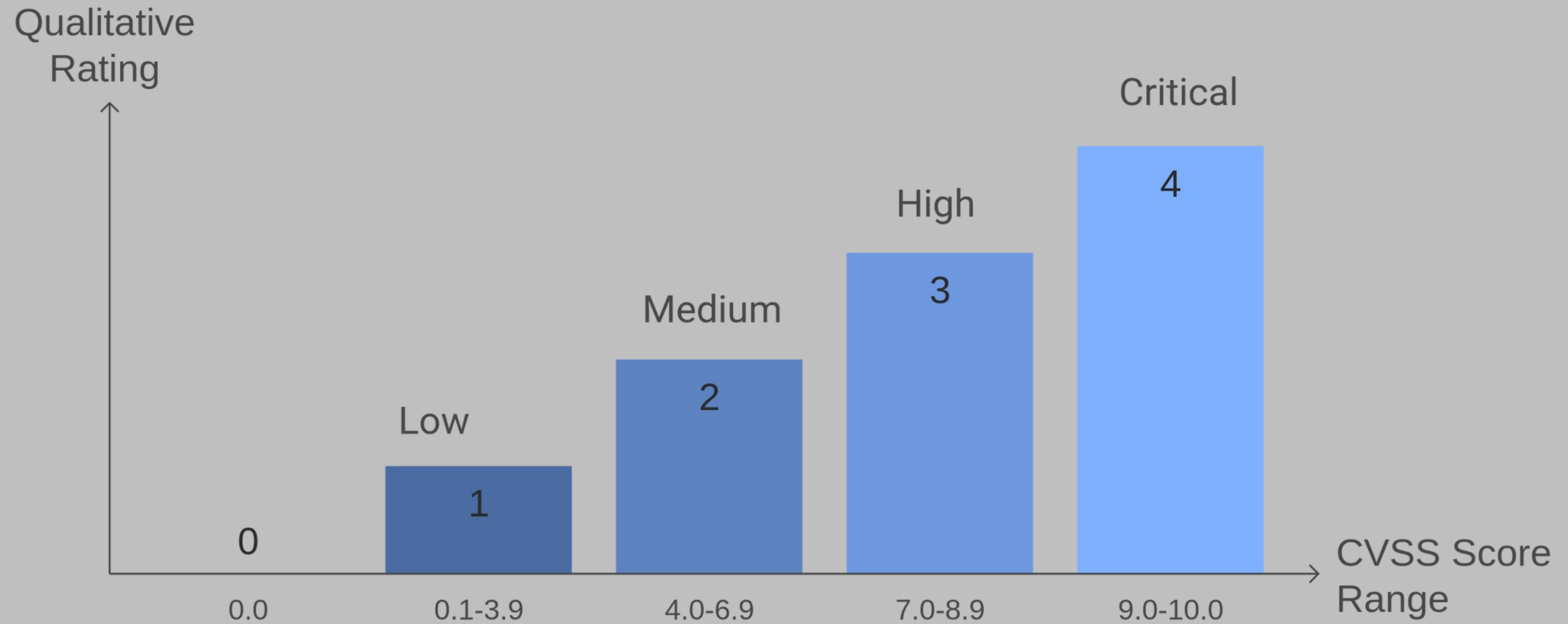
CVSS (Common Vulnerability Scoring System)

- ❑ A **standardized** framework that measures the severity of security vulnerabilities
- ❑ Provides a **standardized method** for rating vulnerabilities based on their **impact**.
- ❑ Assigns a numerical score between 0 and 10 to each vulnerability, **with higher scores indicating more severe issues**

How Does It Work?



CVSS Score



CVSS Score Qualitative Ratings

Base Metrics

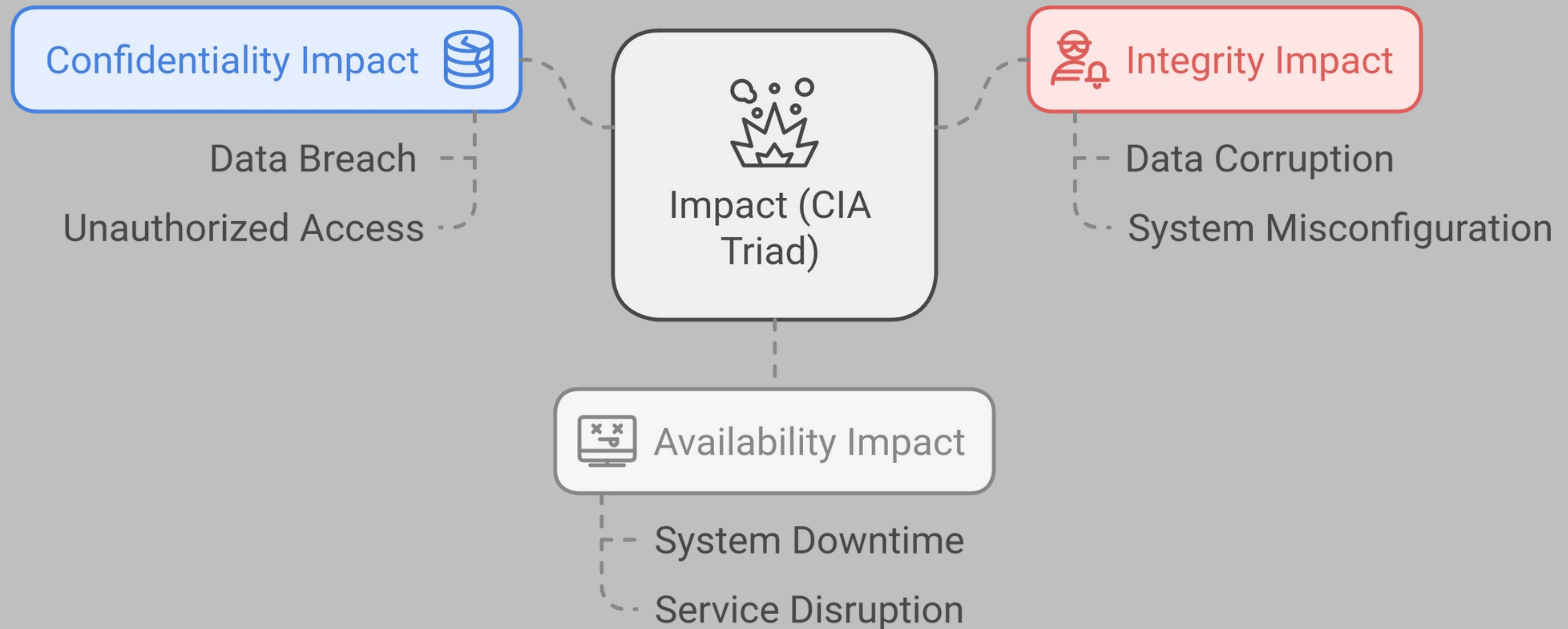
DESCRIBES CORE unchanging **CHARACTERISTICS OF THE VULNERABILITY.**
INCLUDES _____

Metric	Description	Values
Attack Vector (AV)	How the vulnerability is exploited.	Network (N), Adjacent (A), Local (L), Physical (P)
Attack Complexity (AC)	Difficulty of exploitation.	Low (L), High (H)
Privileges Required (PR)	Level of access needed by the attacker.	None (N), Low (L), High (H)
User Interaction (UI)	Whether user action is required.	None (N), Required (R)
Scope (S)	If other components are affected.	Unchanged (U), Changed (C)
Confidentiality (C)	Impact on data confidentiality.	None (N), Low (L), High (H)
Integrity (I)	Impact on data integrity.	None (N), Low (L), High (H)
Availability (A)	Impact on system availability.	None (N), Low (L), High (H)

CVSS PRIMARY METRIC GROUPS

Base Metrics

IMPACT _____

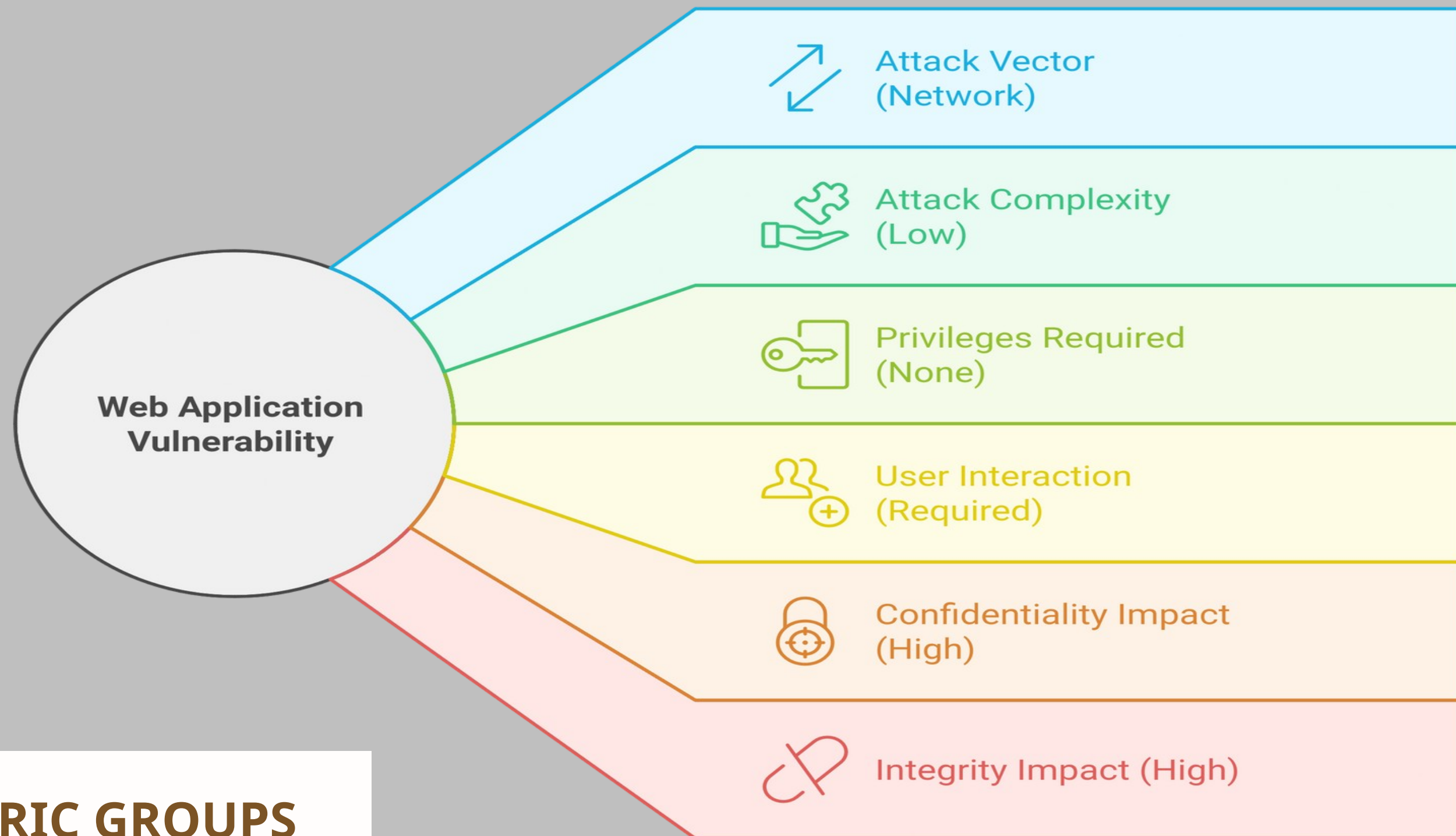


CVSS PRIMARY METRIC GROUPS

Base Metrics

Example

Breaking Down Web Application Vulnerability



CVSS PRIMARY METRIC GROUPS

Temporal Metric

Describe things that might change after the **vulnerability is discovered, i.e. Exploit availability.**

Exploit Code Maturity (E): Measures exploit tool sophistication.

- Values: Not Defined, Unproven, Proof-of-Concept, Functional, High

Remediation Level (RL): Indicates fix availability.

- Values: Not Defined, Unavailable, Workaround, Temporary Fix, Official Fix

Report Confidence (RC): Reflects certainty of vulnerability.

- Values: Not Defined, Unknown, Reasonable, Confirmed

Temporal

Exploit Code
Maturity

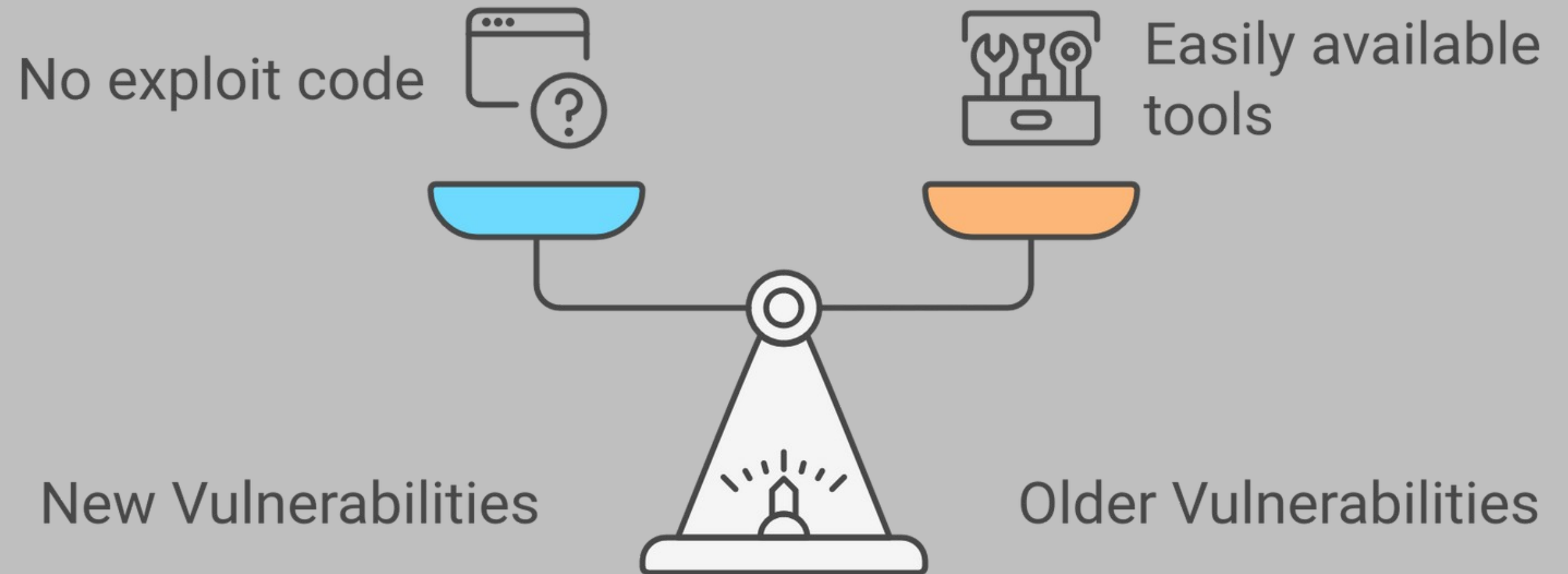
Remediation
Level

Report
Confidence

Temporal

EXPLOIT CODE MATURITY Metrics

A **new bug** might have no exploit code yet, but **older bugs** might have easily available tools to **exploit** them.

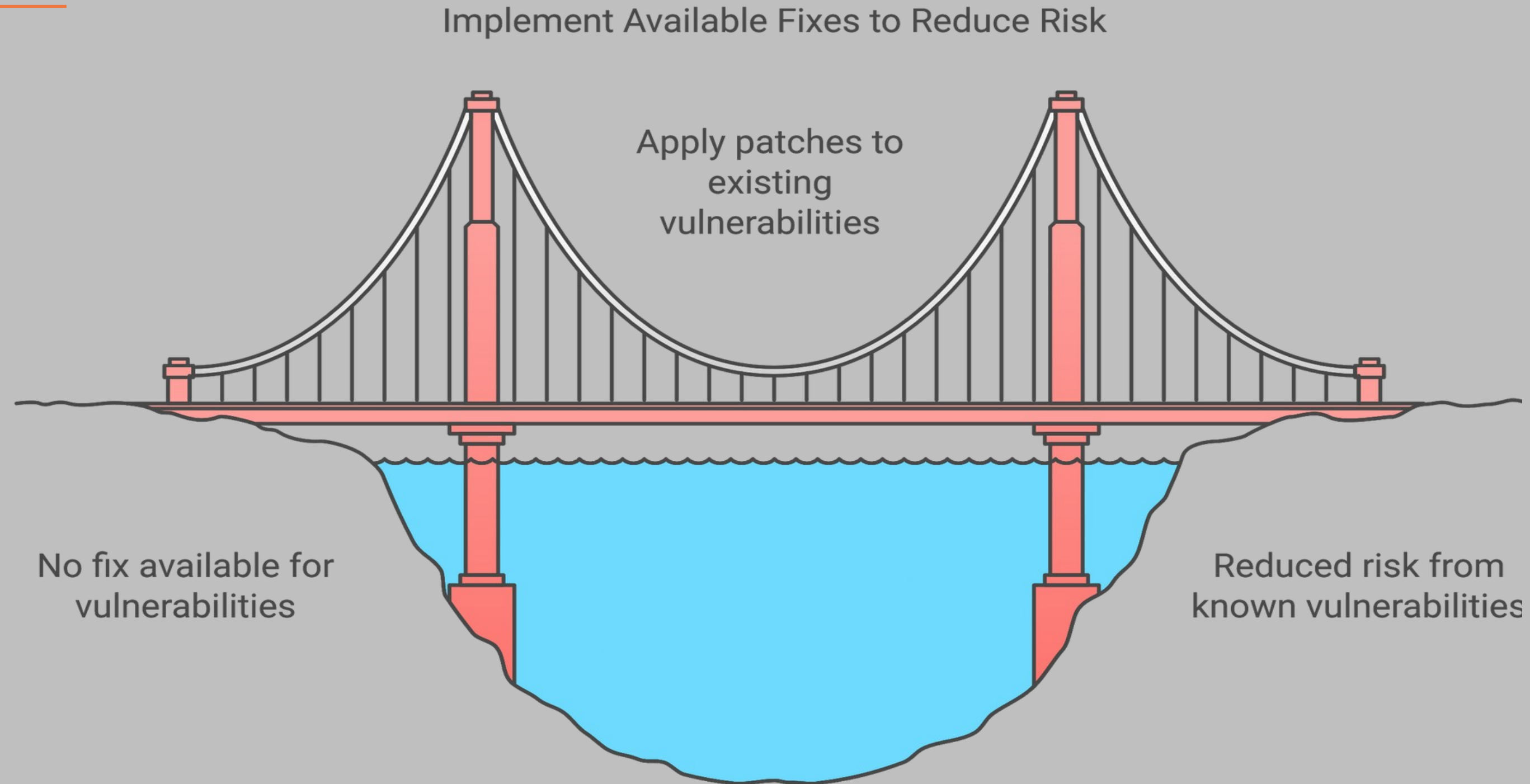


Compare exploit code maturity for risk assessment.

Temporal

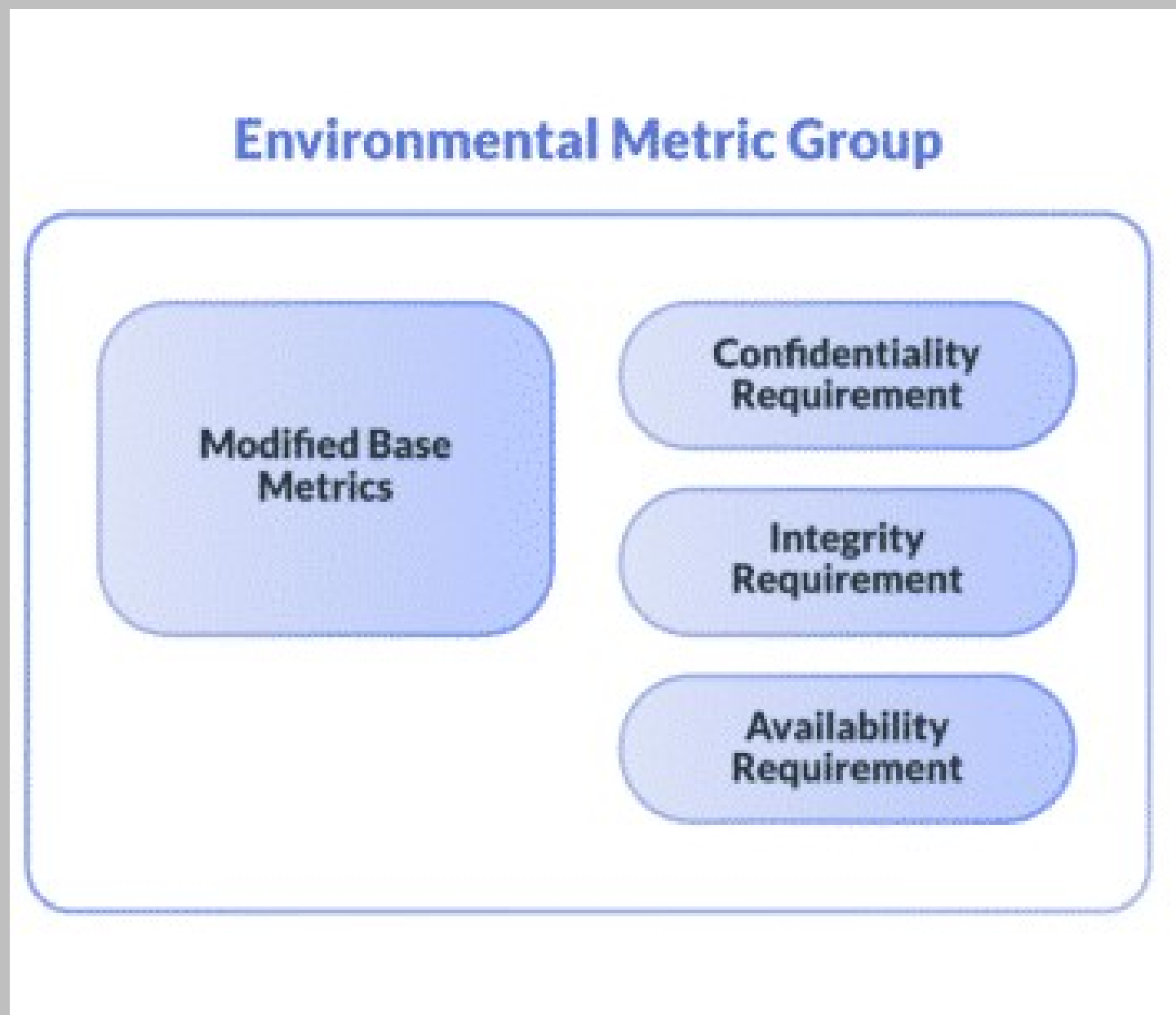
REMEDATION LEVEL Metrics

If a **patch** is ready, the risk might go down.



Environmental

These are specific to one's **environment**, meaning the same **vulnerability** might be more severe for one organization than another.



Modified Base Metrics

- Customizes base metrics for specific organizational contexts.

Security Requirements (CR, IR, AR)

- Weigh the importance of Confidentiality, Integrity, and Availability.
- Values: Low, Medium, High.

Environmental Security Requirements Metrics

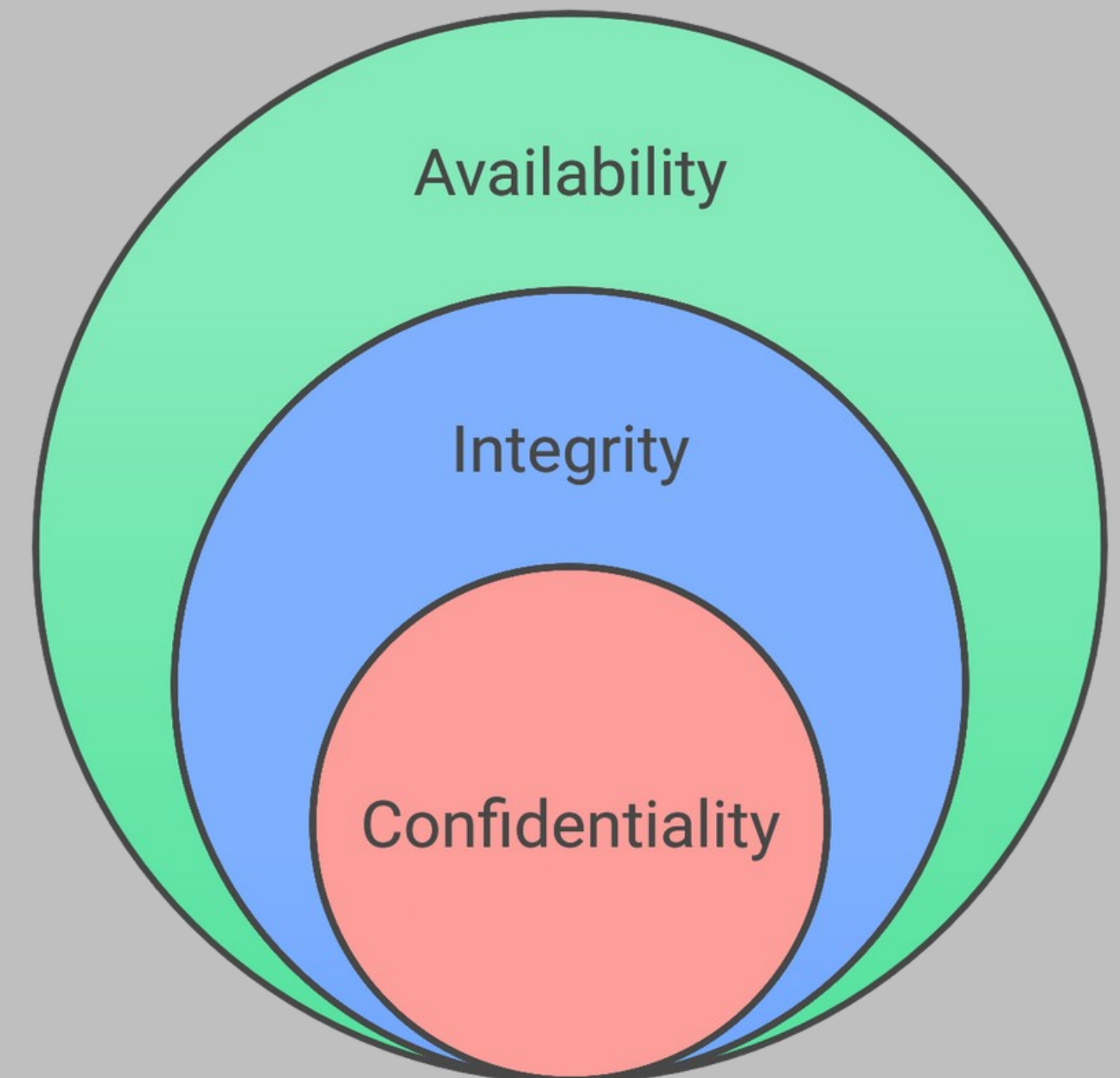
A hospital
might rank
Availability
higher because
downtime
could endanger
lives.

Protects sensitive
information from
exposure

Ensures data
accuracy and
trustworthiness

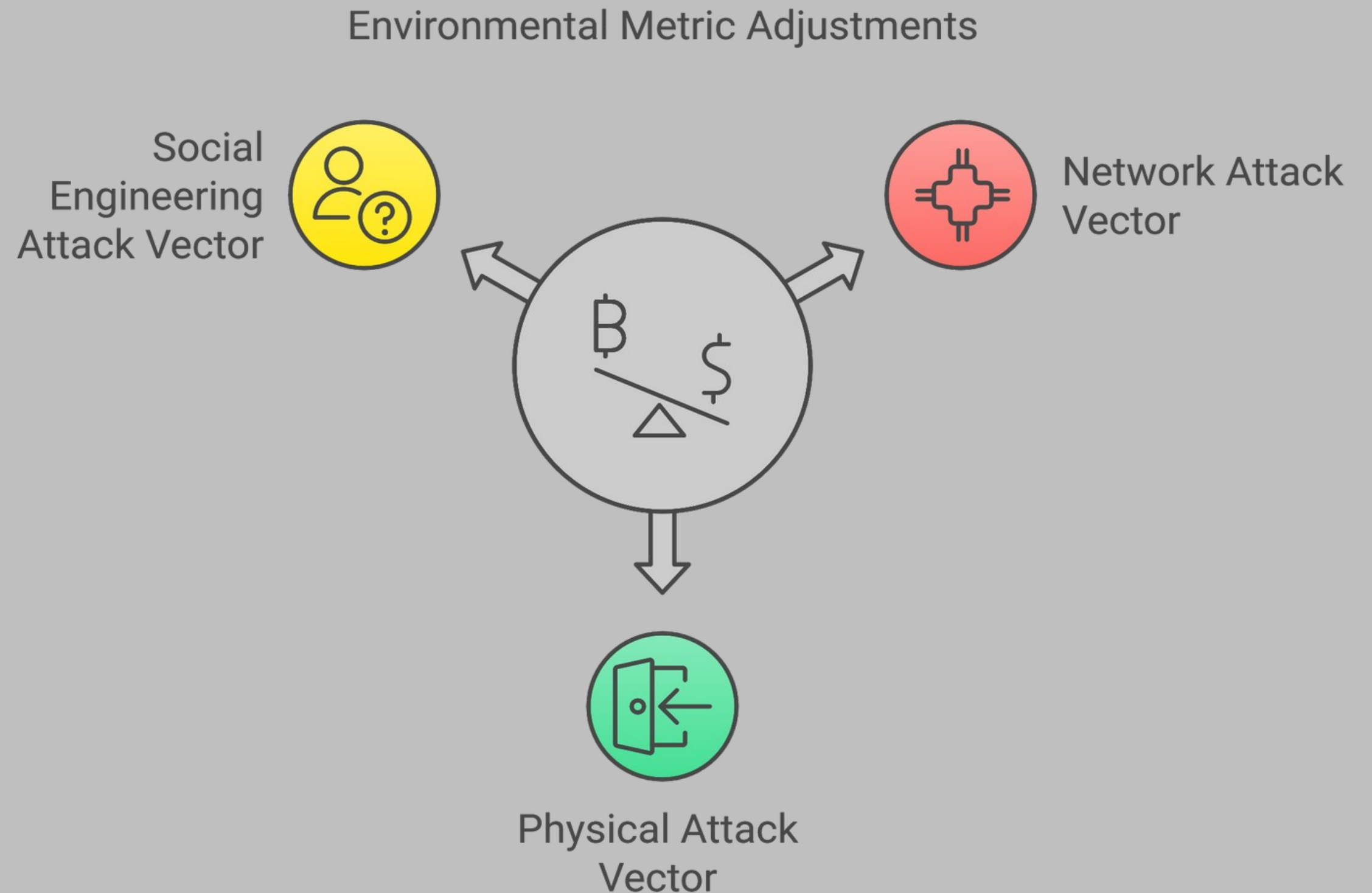
Critical for operational
continuity

Security Requirements Prioritization



Environmental Modified Base Metrics Metrics

If you have no external internet access, the Network attack vector might not apply.



Activities in CVSS

Activity	Description
Vulnerability Identification	Identify vulnerabilities in software, hardware, or systems using CVSS metrics.
Scoring Vulnerabilities	Assign values to Base, Temporal, and Environmental Metrics using the CVSS calculator.
Risk Prioritization	Prioritize remediation based on CVSS scores (e.g., critical vulnerabilities first).
Tracking Changes	Update scores as new exploits or patches become available.
Communication	Share CVSS scores to communicate risks to technical and non-technical stakeholders.

Example of a CVSS

Base Metrics:

- **AV (Attack Vector):** *Network* (N)
- **AC (Attack Complexity):** *Low* (L)
- **PR (Privileges Required):** *None* (N)
- **UI (User Interaction):** *None* (N)
- **C (Confidentiality Impact):** *High* (H)
- **I (Integrity Impact):** *High* (H)
- **A (Availability Impact):** *High* (H)

Environmental Metrics:

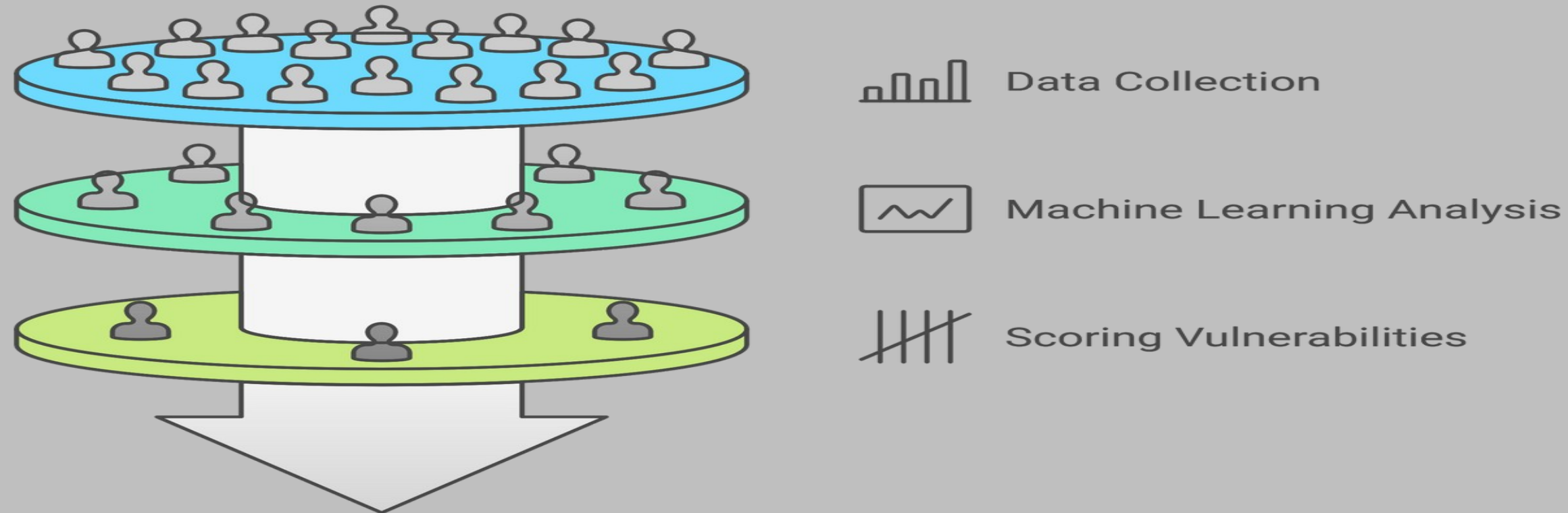
- **Confidentiality Importance:** *High* for critical servers ⚠️

Final Score: 9.8 (Critical) 🔴

Temporal Metrics:

- **Exploit Available:** ✅
- **Remediation Level:** *Official fix*

Predicting Vulnerability Exploitation



EPSS

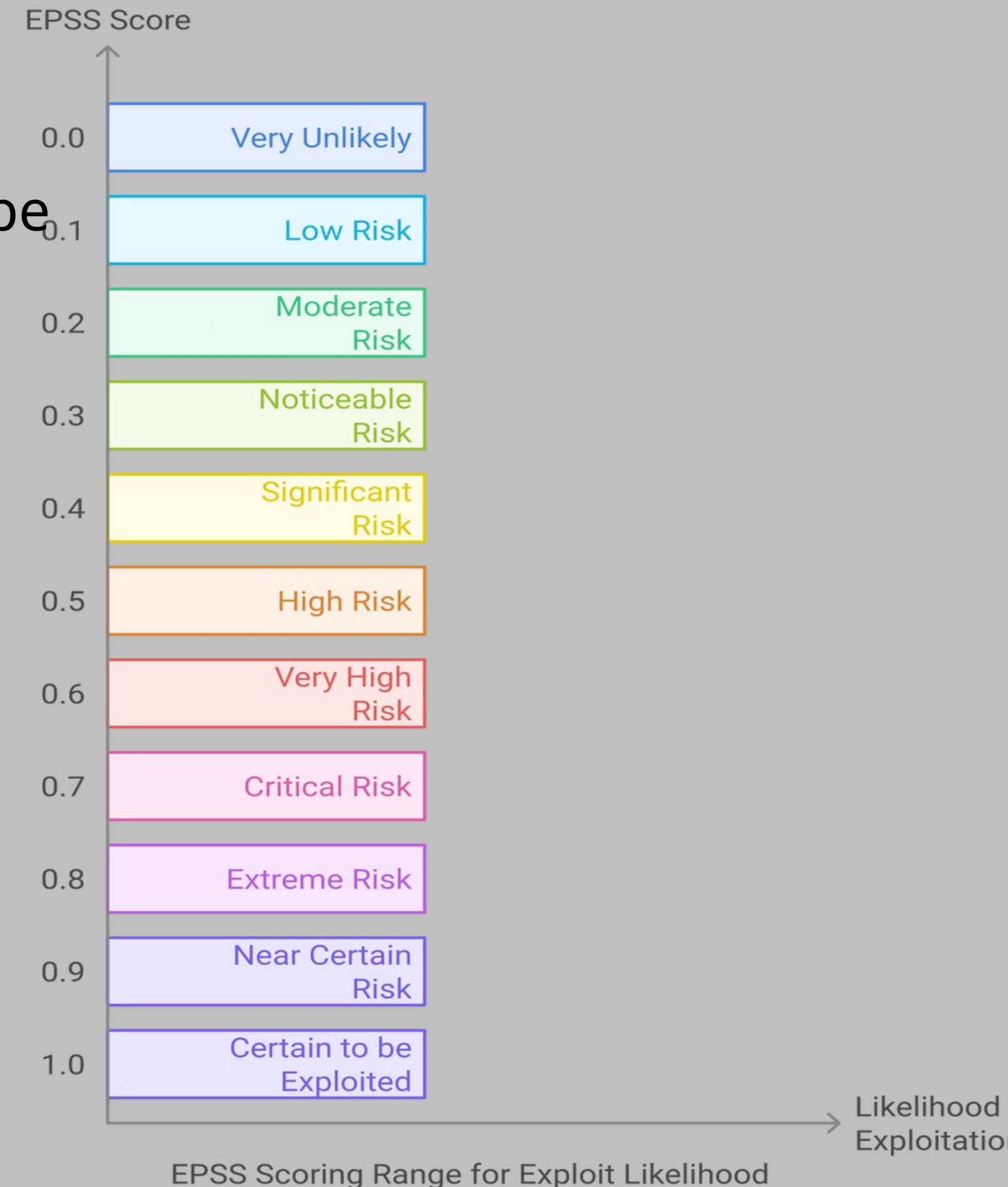
- ❑ EPSS is a **scoring system** that predicts the likelihood of a vulnerability being exploited in the near future. It uses **historical data and machine learning models** to estimate, and hence Dynamic and Data-Driven.
- ❑ Complement CVSS
- ❑ Developed by FIRST (Forum of Incident Response and Security Teams)

Scoring Range

The **EPSS score** ranges from 0.0 (very unlikely to be exploited) to 1.0 (certain to be exploited).

Benefits

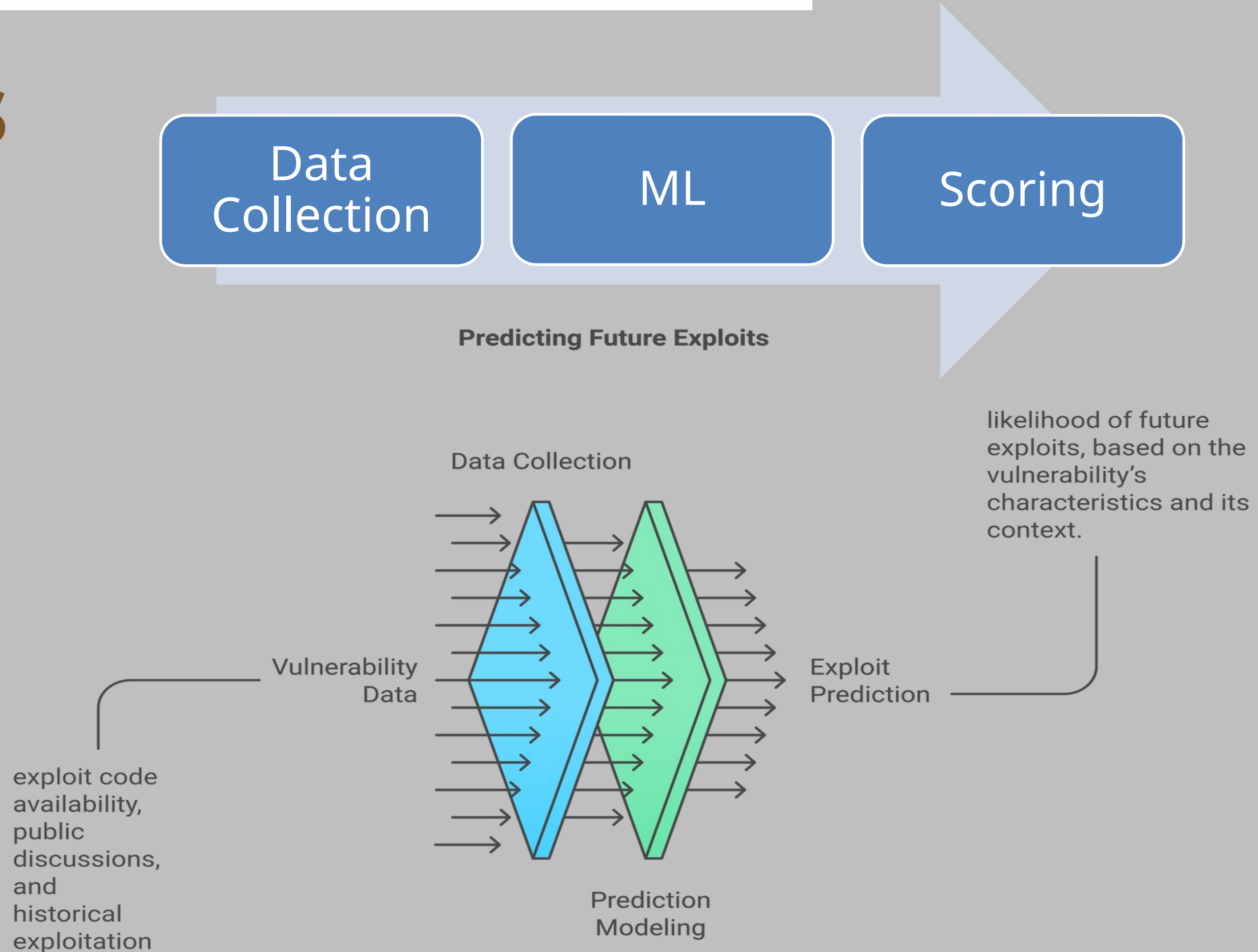
- ❑ Prioritization: Focus on high-risk vulnerabilities
- ❑ Efficiency: Avoid wasting resources on lower-risk vulnerabilities
- ❑ Proactivity: Stay prepared for any potential attacks



EPSS

How It Works

- ❑ Uses information from various data sources like vulnerability database, exploit repositories, real-world attack data.
- ❑ Scores probability of exploitation from 0 to 1 using ML and statistical models.
- ❑ Changes assigned scores as new data becomes available.



Factors Considered in EPSS

CVSS Attributes

- ❑ Exploitation complexity
- ❑ Attack vector
- ❑ Confidentiality, integrity, and availability impact

Historical Data

- ❑ Previous vulnerability exploitation trend
- ❑ Current threat landscape

Public Vulnerability Database

- ❑ Information from databases like NVD (National Vulnerability Database)
- ❑ Likelihood of discovery of the vulnerability

Why EPSS?

- ❑ **Vulnerabilities are constantly discovered.**
- ❑ **Not all vulnerabilities are exploited.**
- ❑ **Focuses efforts on the highest risk.**

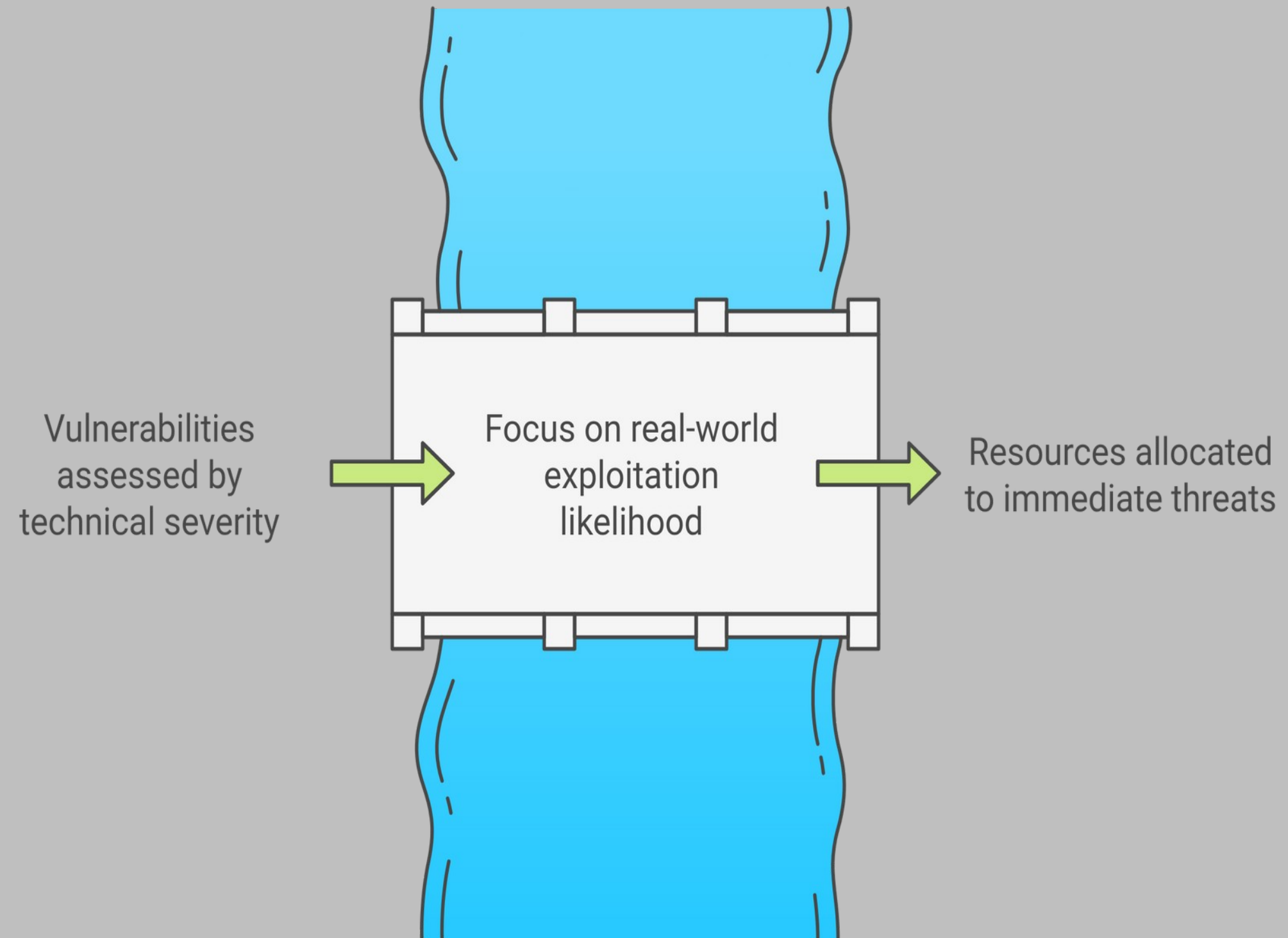
96% of the vulnerabilities scored with EPSS score of less than 0.1, were neither exploited or prioritized for remediation (True Negative (TN)). 1.8% were both exploited and prioritized for remediation (TP).

[Source: https://orca.security/resources/blog/epss-scoring-system-explained/](https://orca.security/resources/blog/epss-scoring-system-explained/)

Challenges Addressed

- ❑ Overwhelming Number of Vulnerabilities
- ❑ Ineffective Prioritization
- ❑ Resource Constraints

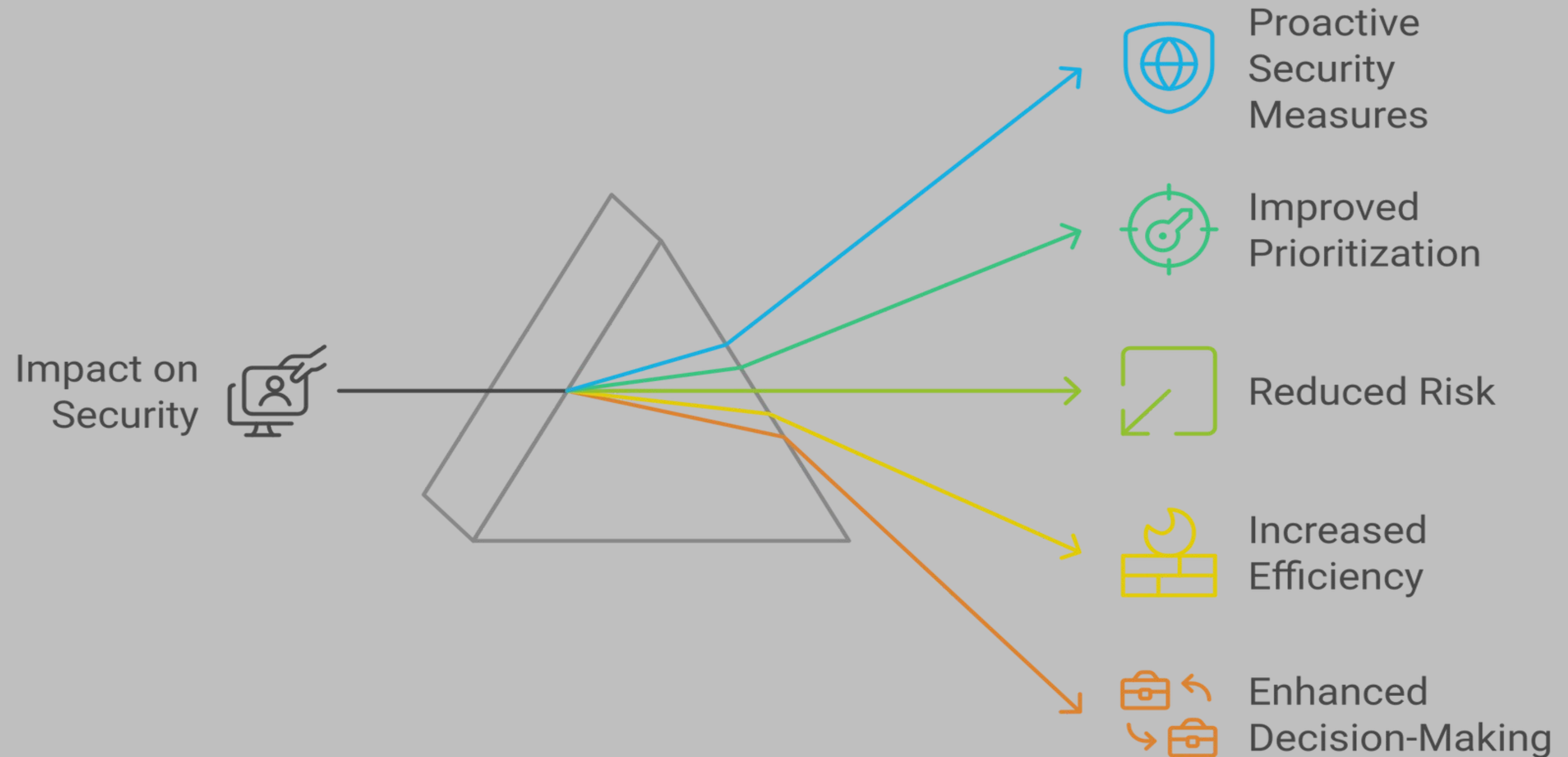
Prioritize vulnerabilities for effective resource allocation



EPSS

Impacts

Unveiling the Multifaceted Impact on Security



How to Use EPSS?

- ❑ Access EPSS scores through the FIRST website. <https://www.first.org/epss/>
- ❑ Integrate EPSS into vulnerability management workflow.
- ❑ Use EPSS to complement CVSS and other security tools.

EPSS in Action

1. A vulnerability with CVSS 9 but EPSS 0.05

Action: **lower priority**

2. A vulnerability with CVSS 7 but EPSS 0.9

Action: **higher priority**

EPSS vs CVSS

EPSS

- Predicts the likelihood of exploitation
- Offers a score between 0 and 1
- Leverages dynamic data like exploit availability, threat intelligence, and past exploitation patterns.

02

CVSS

- Measures the severity of a vulnerability
- Provides a score from 0 to 10 based on factors
- Uses static vulnerability attributes.



**THANK
YOU!**